

ACCESS CONTROL POLICY

Document Title	Access Control Policy	Document ID	ISMS-POL-002
Version	1.0	Status	<i>DRAFT — Pending Approval</i>
Author	Head of Engineering / ISMS Lead	Date	June 2026
Approved By	Head of Engineering & ISMS Lead	Next Review	June 2027
Related Documents	ISMS-POL-001 (Information Security Policy), ISMS-DOC-001 (Scope Statement), ISMS-DOC-006 (Risk Assessment — R-001, R-012)		

1. PURPOSE AND BACKGROUND

This policy establishes Tumaini Capital's requirements for controlling access to information systems and data. It defines how access rights are granted, managed, reviewed, and revoked throughout the lifecycle of the employment or engagement relationship.

This policy was created in direct response to a confirmed information security incident in 2025 in which a former employee's access to the Customer Relationship Management (CRM) system was not revoked upon their departure, resulting in the unauthorized export of customer telephone numbers. This policy closes that gap and prevents recurrence.

2. SCOPE AND DEFINITIONS

This policy applies to all Tumaini Capital staff, contractors, and third-party suppliers who have access to in-scope information systems, including the CRM system, core lending platform, AWS cloud infrastructure, Google Workspace, and any other system containing customer, borrower, or organizational data.

2.1 Definitions

- Access rights: permissions granted to a user or process to read, write, modify, delete, or execute information on a system.
- Joiner: a new employee, contractor, or third-party user being granted system access for the first time.
- Mover: an existing user whose role changes, requiring modification of their access rights.
- Leaver: an employee, contractor, or third-party user whose engagement with Tumaini Capital ends for any reason.
- Privileged access: administrative or elevated system access that allows a user to manage configurations, accounts, or security settings beyond standard user capabilities.
- Need-to-know: the principle that access is granted only where a legitimate and documented business requirement exists.

3. ACCESS CONTROL PRINCIPLES

All access to Tumaini Capital's information systems shall be governed by the following principles:

- Least privilege: users shall be granted the minimum access required to perform their job function. No user shall have access to systems or data beyond what their role requires.
- Need-to-know: access to sensitive or restricted information (including KYC data and loan records) shall be granted only where a specific and documented business need exists.

- Segregation of duties: where possible, no single user shall have end-to-end control over a critical or high-risk process. Where full segregation is not feasible due to team size, compensating controls (peer review, audit logging) shall be documented and applied.
- Formal approval: all access requests shall be approved by the relevant system owner and the user's line manager before provisioning.
- Regular review: all access rights shall be reviewed at least quarterly. Access that is no longer justified shall be revoked immediately.

4. JOINER, MOVER, AND LEAVER (JML) PROCESS

The JML process is the most critical control in this policy. Its failure directly caused the 2025 CRM incident. Adherence is mandatory.

4.1 Joiners

When a new employee, contractor, or third-party user requires system access:

- The line manager shall submit a formal access request at least three business days before the individual's start date.
- The request shall specify each system required and the level of access needed, with a justification.
- The Head of Engineering or designated system owner shall approve and provision access before the start date.
- The new user shall be issued with a unique personal account. No shared accounts shall be created.
- Access provisioning shall be recorded in the Access Rights Register.

4.2 Movers

When an employee or contractor changes role, department, or responsibilities:

- The line manager shall notify IT within three business days of the change becoming effective.
- Access rights shall be reviewed and adjusted to reflect the new role within five business days.
- Access no longer required shall be revoked. New access shall be provisioned following the Joiner process.

4.3 Leavers — MANDATORY SLA: 24 HOURS

When an employee, contractor, or third-party user's engagement ends for any reason, including resignation, redundancy, dismissal, end of contract, or retirement:

- HR shall notify the Head of Engineering and ISMS Lead on the same day as the leaver's final working day, or earlier if known in advance.
- ALL system access shall be deactivated within 24 hours of the employment or engagement ending. This includes access to the CRM, core lending platform, AWS, Google Workspace, and any other in-scope system.
- Physical access credentials (keycards, device access) shall be revoked and company equipment returned on the final working day.
- The deactivation shall be confirmed in writing by the Head of Engineering to HR and the ISMS Lead.
- Failure to comply with the 24-hour SLA shall be reported as a security incident.

Note: the 2025 CRM incident occurred because this process was not followed. Compliance with this section is non-negotiable.

5. PRIVILEGED ACCESS MANAGEMENT

Privileged access to administrative, configuration, or security management functions carries elevated risk and requires additional controls:

- All privileged users shall be issued with a separate, named privileged account distinct from their standard user account. Privileged accounts shall not be used for routine tasks such as email or document editing.
- No shared or generic admin accounts are permitted on any in-scope system. Every privileged action must be traceable to a named individual.
- Multi-factor authentication (MFA) is mandatory on all privileged accounts without exception.
- A register of all privileged accounts shall be maintained by the Head of Engineering and reviewed quarterly.
- Privileged access shall be reviewed quarterly. Any privileged account that is no longer required shall be deactivated immediately.
- All privileged activity shall be logged. Logs shall be retained for a minimum of 12 months.

6. AUTHENTICATION STANDARDS

The following authentication standards apply to all Tumaini Capital accounts on in-scope systems:

- Minimum password length: 12 characters.
- Passwords must contain at least one uppercase letter, one lowercase letter, one number, and one special character.
- Passwords must not contain the user's name, username, or common dictionary words.
- Passwords must not be reused from the previous 12 passwords.
- Multi-factor authentication (MFA) is mandatory for all access to: AWS Management Console, Google Workspace (email and Google Drive), the CRM system, and all remote access to in-scope systems.
- Default or vendor-supplied passwords must be changed before any system is placed into production.
- Passwords must never be shared, written down in unsecured locations, or transmitted via email or messaging applications.

Staff are encouraged to use a reputable password manager to manage unique passwords across systems.

7. REMOTE ACCESS AND BYOD

- Remote access to in-scope systems shall require MFA in all cases.
- Personally-owned mobile devices (BYOD) used for business purposes shall comply with the BYOD and Remote Working Policy.
- BYOD devices must have screen lock enabled (maximum 5-minute timeout) and full-disk encryption where technically available.
- The organization reserves the right to remotely wipe Tumaini Capital data from a lost, stolen, or compromised personal device.
- Sensitive data, including KYC documents and loan records, must not be stored permanently on personal devices.

8. THIRD-PARTY AND SUPPLIER ACCESS

- Third-party suppliers requiring access to in-scope systems shall be granted only the minimum access necessary for the delivery of contracted services.
- All third-party access shall be individually named — no shared accounts for supplier personnel.
- Third-party access shall be subject to the same JML process, including deactivation within 24 hours of contract end.
- Supplier access rights shall be reviewed annually, or more frequently where the supplier relationship changes.

- The outsourced IT MSP's access rights shall be reviewed at least annually and documented in the Supplier Risk Register.

9. PERIODIC ACCESS REVIEWS

All access rights to in-scope systems shall be reviewed at least quarterly. Reviews shall be conducted by the Head of Engineering in coordination with each system owner and line manager. The review shall confirm that:

- Every active account belongs to a current and active employee, contractor, or third party.
- Each user's access level remains appropriate for their current role.
- No accounts inactive for 90 or more days remain enabled without documented justification.

Review results shall be documented and retained for a minimum of 12 months as audit evidence.

10. POLICY VIOLATIONS

Violations of this policy shall be treated as information security incidents and reported through the incident reporting channel. Violations may result in disciplinary action up to and including termination of employment or contract. Violations that result in a personal data breach may also be reported to the ODPC as required under the Data Protection Act, 2019.

11. REVIEW

This policy shall be reviewed annually, following any significant change to the system landscape or access management tooling, and following any access-related security incident.

Role	Name & Signature	Date
Head of Engineering (Technical Owner)		
Head of Risk & Compliance / ISMS Lead		
Chief Executive Officer (Final Approver)		